Part1：隐私政策文本分析与权利识别

基于 run_audit.py Prompt 的同意权、访问/查询权、删除权、知情权识别

李禹江，张博涵，蒋兴宇

我的刀盾队

2026-04-27

目录

1. 实验定位
2. Prompt 设计
3. 实验结果
4. 总结与后续

本次实验主题：隐私政策文本分析 + Prompt 工程

- **实验目标**：从隐私政策句子中识别用户权利文本，重点关注同意权、访问/查询权、删除权、知情权。
- **核心问题**：政策是否只是“声明权利”，还是同时给出可执行路径、渠道、数据对象和处理时限。
- **主要方法**：使用 `run_audit.py` 中的 LLM prompt；通过法条口径、字段枚举和 few-shot 示例约束输出。
- **产出形式**：每句生成结构化 JSON，并落到 CSV 字段中，支持统计分析、人工复核和后续动态验证。

实验手册口径与本次实现对应

汇报要点	本次 Part1 覆盖内容
实验目的	识别隐私政策中同意权、访问/查询权、删除权、知情权等用户权利文本
实验环境	Windows + Python；DeepSeek 作为 LLM 后端；BGE 句向量与聚类辅助上下文
实验内容	使用 `run_audit.py` prompt 做句级权利识别，支持 few-shot 与同簇上下文
实验结果	23 款应用、9639 句；输出 right_claim、right_types、method_claim、path_text 等字段
后续思路	用人工标注和动态验证校准 prompt 边界，形成“文本识别—验证—修正”的闭环

Prompt 来源：run_audit.py 的角色与任务约束

- **System Prompt**：模型被限定为“中文 Android 隐私政策与用户隐私权执行方式分析助手”。
- **法律依据**：以《个人信息保护法》中的个人信息、个人信息处理、用户权利为判断基础。
- **分析对象**：不是整篇政策一次性判断，而是逐句识别用户权利、执行渠道、动态验证目标与可用性风险。
- **工程要求**：只输出严格 JSON，便于后处理为 CSV 字段并做批量统计。


```
{"right_claim":1,"method_claim":1,"right_types":["access_copy"],"path_text":"账号资料页","usability_risk":"mediu
```

识别对象：四类重点权利文本

权利类型	Prompt 判标口径	典型关键词/路径
知情权/决定权	告知收集哪些数据、为何收集、如何使用、存储、共享、删除；或提供限制/拒绝控制	收集、使用、共享、目的、范围、关闭
同意权/撤回同意	用户可同意、拒绝、授权、关闭、撤回授权或调整权限	同意、授权、拒绝、撤回、关闭
访问权/查询权	用户可查询、查阅、访问、复制、下载或导出个人信息	查询、查阅、访问、复制、下载副本、导出数据
删除权	用户可删除/清除个人信息，或通过注销账号实现删除/匿名化	删除、清除、注销账号、匿名化

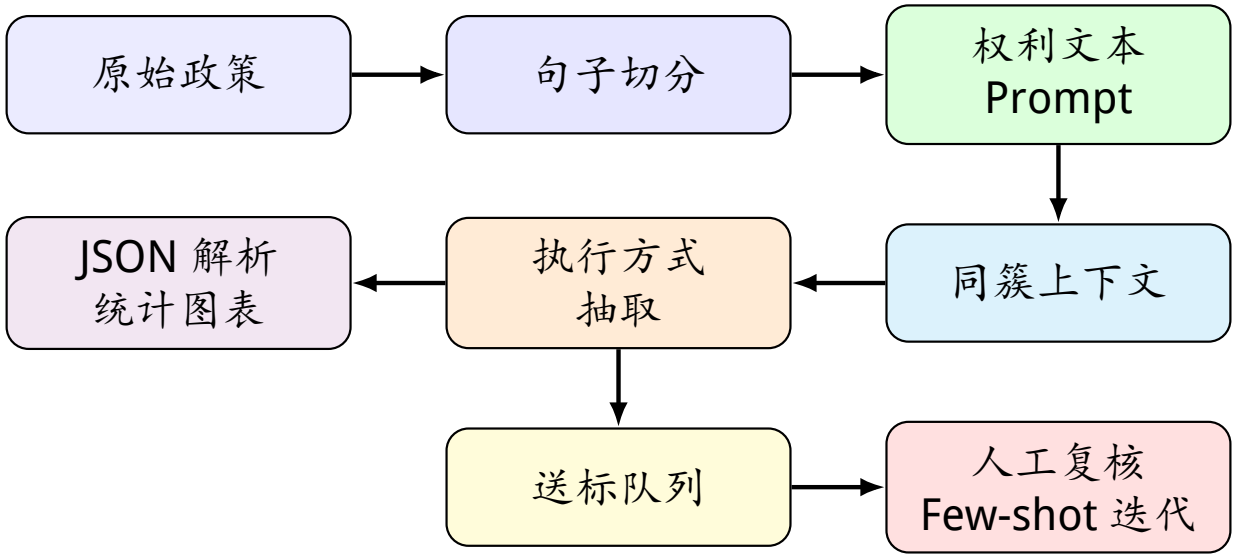
结构化字段：把权利识别落到可分析数据

- **right_claim**：是否出现用户权利、数据控制或知情内容。
- **right_types**：枚举同意、访问复制、删除、注销等权利类别。
- **method_claim**：是否给出路径、入口、邮箱、网页、客服或处理时限。
- **path_text**：摘录最具体的执行路径或联系方式。
- **target_data**：抽取权利指向的数据对象。
- **app_test_candidate**：判断是否适合进入 Appium/网页/人工验证。

Few-shot：用样例固定判标边界

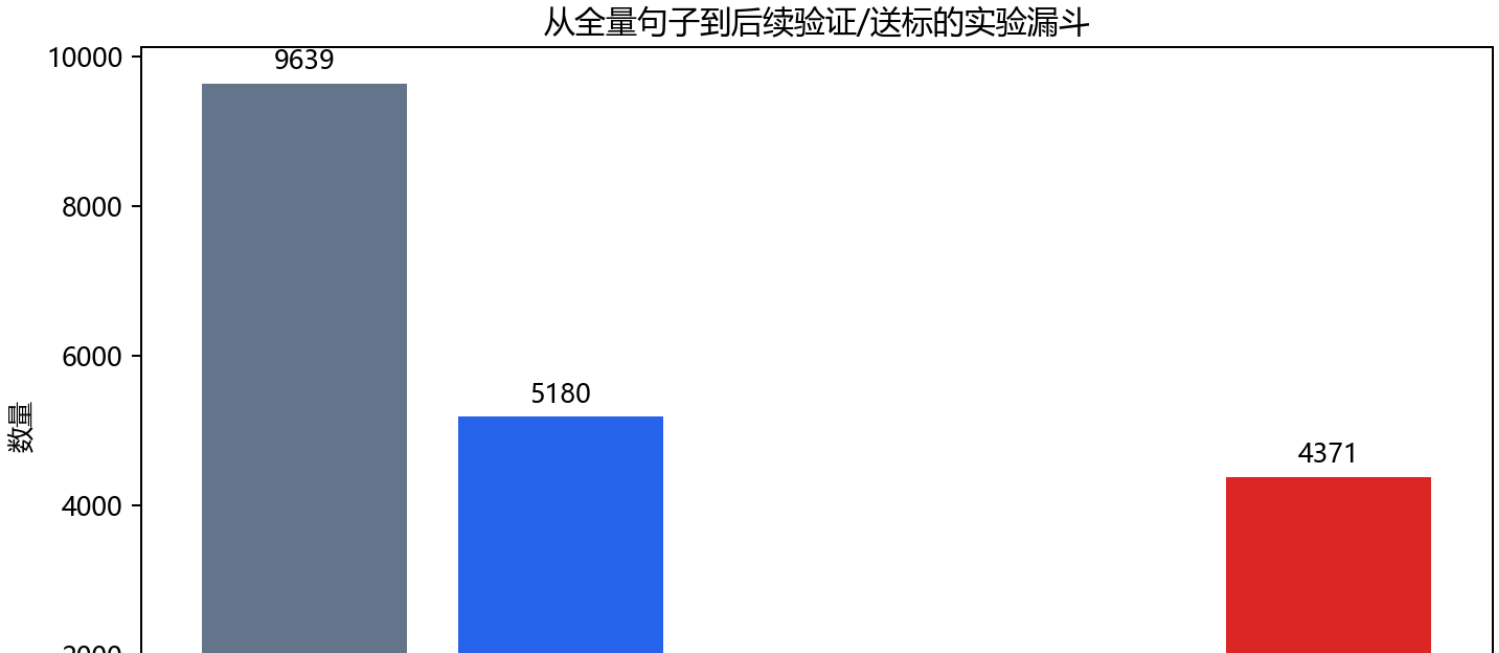
- **作用**：让模型区分“空泛声明权利”和“给出可执行路径”的差异。
- **样例覆盖**：低风险 App 内路径、邮箱/客服渠道、笼统“联系我们”、查询但不可导出、可下载个人信息副本、注销删除等。
- **访问/查询细分**：通过 `access_copy_type` 区分 `copy`、`non_copy`、`unknown`。
- **后续迭代**：把人工复核中的误判样例补回 few-shot，提升边界一致性。

端到端流程：Prompt 位于流水线核心

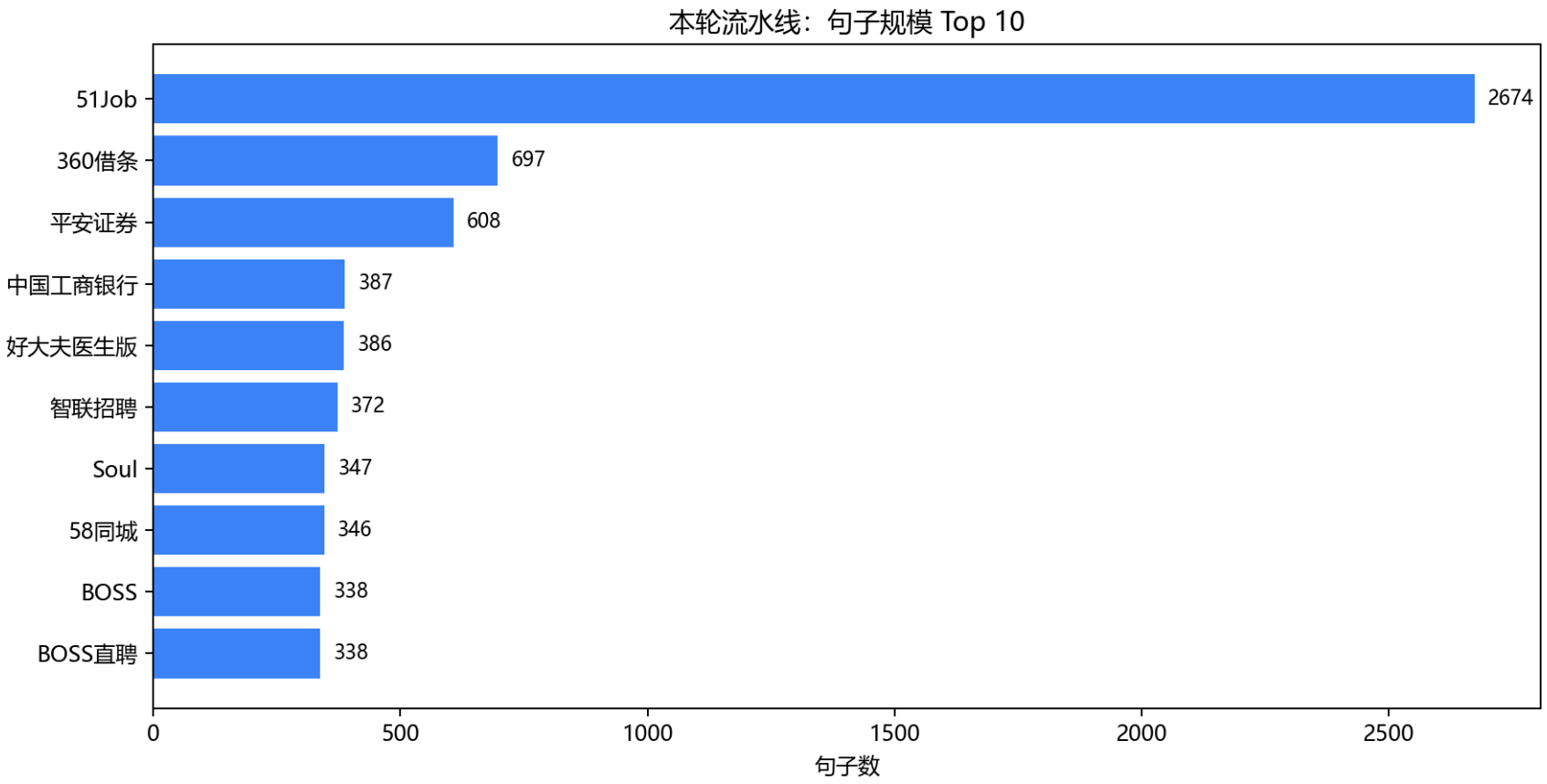


实验设置与整体规模

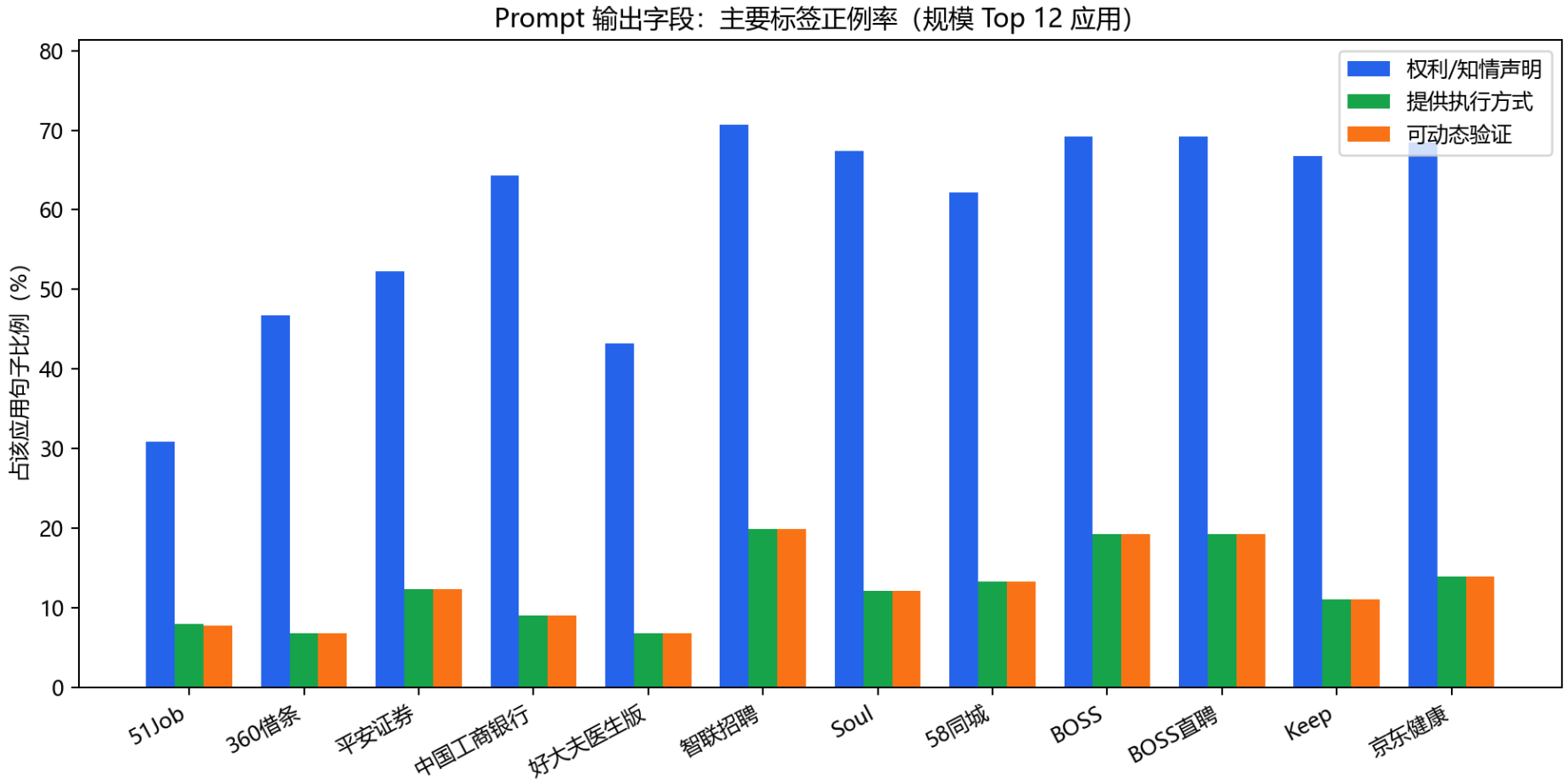
- **运行目录**：run_20260427_001723。
- **LLM 后端**：DeepSeek；**审计 prompt**：来自 run_audit.py；**limit**：0，即全量运行。
- **Few-shot**：在 prompt 中内置多类权利执行样例；分类阶段也支持外部 shots 注入。
- **上下文**：审计前聚类开启，把同簇句子作为参考上下文，最终仍只给当前句打标。
- **数据规模**：23 款应用，共 9639 句；累计送标候选 4371 条。



数据规模：句子数 Top 10

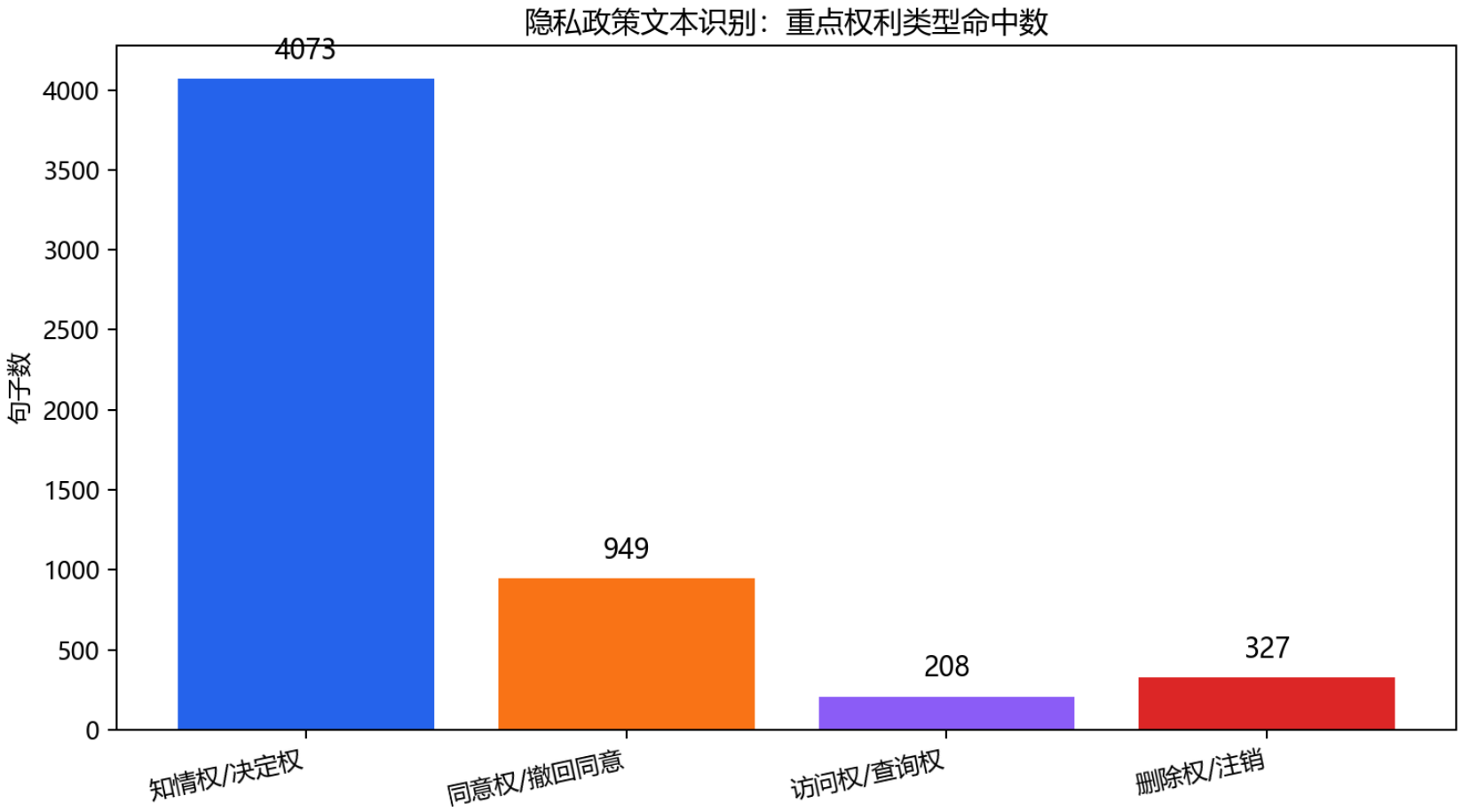


Prompt 输出结果：主要标签正例率



结果显示，**right_claim** 主要捕捉权利/知情文本，**method_claim** 和 **app_test_candidate** 更关注是否给出可执行路径。

重点权利类型识别结果



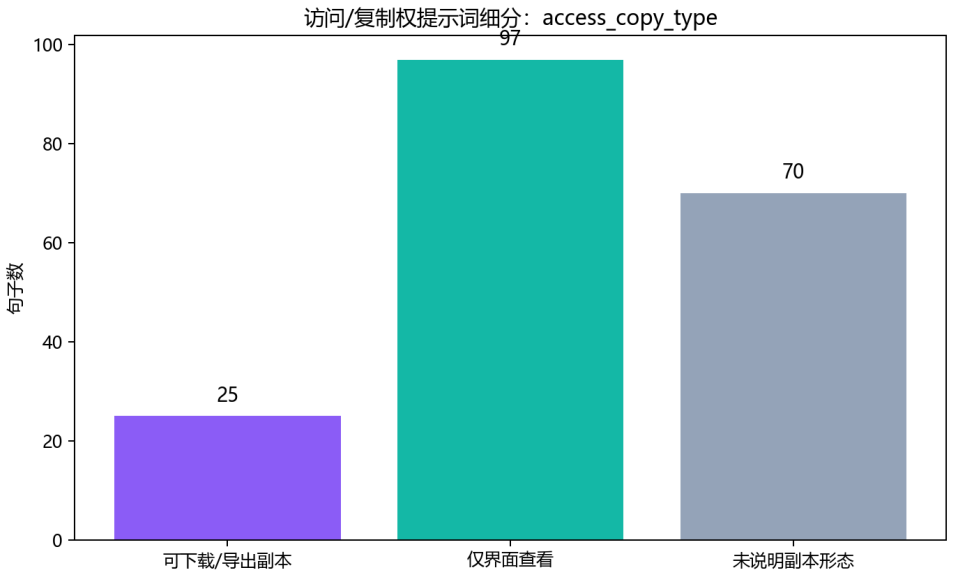
同一句可能同时命中多个 `right_types`，因此各类权利计数之和可能大于 `right_claim` 总数。

Top 应用统计表

应用	句数	right	method	candidate	method 率
51Job	2674	826	213	207	8.0%
360 借条	697	326	47	47	6.7%
平安证券	608	318	75	75	12.3%
中国工商银行	387	249	35	35	9.0%
好大夫医生版	386	167	26	26	6.7%
智联招聘	372	263	74	74	19.9%
Soul	347	234	42	42	12.1%
58 同城	346	215	46	46	13.3%
合计	**9639**	**5180**	**1053**	**1046**	**10.9%**

观察：权利文本数量较高，但真正给出执行路径的句子占比明显更低，这说明 Prompt 需要把“有权利声明”和“可操作路径”分开抽取。

访问复制权：副本形态进一步细分



- **copy**：能下载、导出、保存为副本，适合验证数据可携带性。
- **non_copy**：只能在界面内查看，常见于账号资料页。
- **unknown**：只声明查阅/复制权，但未说明路径或副本形态。

执行方式识别率较高的应用

应用	句数	method	method 率	copy/non/unknown
智联招聘	372	74	19.9%	4/4/6
BOSS	338	65	19.2%	0/8/4
BOSS 直聘	338	65	19.2%	0/8/4
心脏健康研究	73	12	16.4%	0/1/2
支付宝	247	35	14.2%	1/1/0
Blued 极速版	192	27	14.1%	0/2/2

这类应用适合作为后续动态验证的优先样本，因为 Prompt 已抽取出较多路径、渠道或测试目标。

阶段性结论

- **实验对象更明确**：本轮不是泛化的隐私分类，而是面向同意、访问/查询、删除、知情等用户权利文本识别。
- **Prompt 输出可解释**：`right_types` 说明“识别到什么权利”，`path_text` 说明“用户如何执行”。
- **结果可进入下一阶段**：`dynamic_test_goal` 与 `app_test_candidate` 可转化为 Appium/网页/人工核查清单。
- **Few-shot 是主要迭代入口**：人工复核后的分歧样例可以持续补强 prompt 的边界案例。

实验过程和结构还可提高的地方

- **建立人工真值集**：每类权利抽样标注，分别评估同意权、访问/查询权、删除权、知情权的 Precision/Recall/F1。
- **拆分 prompt 任务**：先识别权利类型，再抽取路径/渠道/数据对象，降低一个 prompt 同时完成多任务的混淆。
- **Few-shot 分层**：按权利类型维护示例库，尤其补足“只有权利声明但无路径”“查询但不可导出”“删除依赖客服”等边界例。
- **增加一致性检查**：同一句多次推理或多模型交叉验证，对不稳定样本优先送标。
- **闭环验证**：将 `app_test_candidate=1` 转为动态测试任务，记录政策路径在真实 App/网页中是否存在、是否可达。

后续实验路线

1. 从本轮结果中按权利类型与风险等级抽样，形成小规模人工金标集。
2. 基于误检/漏检样例重写 few-shot，分权利类型迭代 prompt。
3. 对有明确路径的样本做 Appium/网页验证，检查“文本承诺”与“实际入口”是否一致。
4. 将文本识别、人工标注、动态验证结果合并，形成最终可解释的隐私权利执行评估报告。

感谢聆听！